V VOLTSENTRY

An inline security proxy for EV charging networks.

Transparent OCPP 1.6-J reverse proxy that inspects every WebSocket frame in real time and quarantines compromised chargers before they reach the backend or destabilise the grid.

Public EV charging runs on weakly-authed WebSockets.

- Chargers speak `OCPP 1.6-J` — JSON frames over a persistent WebSocket to a central management system (CSMS).
- Stations are physically exposed roadside hardware on connections that are often barely authenticated.
- They are soft cyber-physical edge nodes sitting on critical energy infrastructure.

Why it isn't already solved

Cloud CSMS platforms audit after the fact — batch analysis minutes or hours after ingestion, long after an attack has landed.

Hardware retrofits are economically dead — you cannot ship a firewall chip to millions of deployed stations.

THREAT MODEL

Five attack vectors on the charging control plane.

Meter spoofing

Under-report delivered energy so a session bills near zero while real power flows. Billing fraud at fleet scale.

Grid oscillation

Synchronised rapid start/stop of high-power chargers across a cluster to swing local load and trip a distribution transformer.

Session shadowing

A parallel WebSocket handshake reusing a live `chargePointId` to displace or seize a legitimate charger's session.

Subtle data drift

Slow compounding falsification that stays inside every hard threshold — invisible to any rule engine.

Card cloning

A copied RFID card charging two cars at once, often at two different sites — invisible to any single site.

Pure software at the transport layer.

- A transparent reverse proxy between the charger and the CSMS. Clean traffic is relayed `8000 → 9000` untouched, both directions.
- Sub-millisecond design budget. No hardware change. Drop-in in front of an existing CSMS — the backend never knows it's there.
- Every frame is parsed, the session state machine is enforced, and a dual-tier detection engine scores it before it is forwarded.
- On a Tier-1 block: drop the frame, send `ChangeAvailability` to the charger, close the socket `4001`.

Station identity

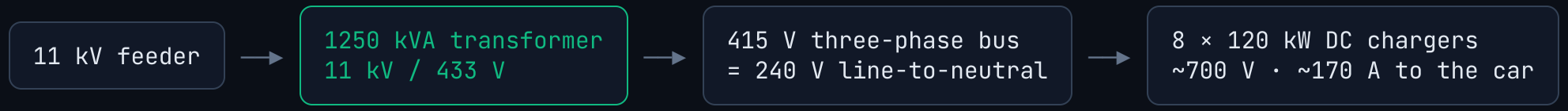
Taken from the URL path — `ws://…/ocpp/CP-04` — parsed at handshake, before any frame arrives. The proxy opens the matching upstream socket per station and keeps a `pending` call map so a `CALLRESULT` can be correlated to the `CALL` that produced it.

One process on the wire. Two detection tiers. One live feed.



- OCPP frames are JSON **arrays** — `[2,id,action,payload]` / `[3,id,payload]` / `[4,id,code,desc,details]`. A `CALLRESULT` carries no action name; the proxy correlates it itself.
- The dashboard feed is a **separate** plain WebSocket on `:8100` — no Socket.io, no path-routing on the OCPP port.

Every figure is in its real unit, read off the wire.



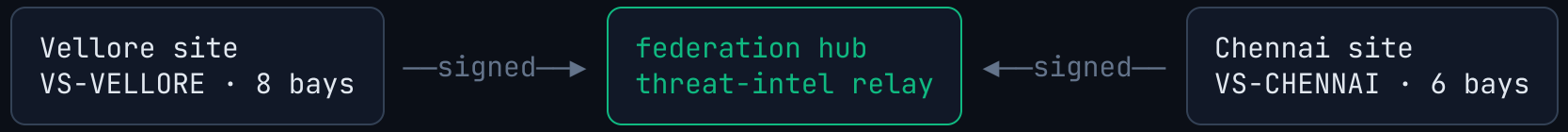
- A house takes **one phase, ~230 V**. A fast charger needs all three: 415 V between lines, 240 V from each line to neutral.
- Transformers are rated in **kVA**, not volts: kVA = kW ÷ power factor. Eight bays draw 1022 kVA, so the site needs **1250 kVA**. (Our hackathon build assumed 500 kVA, which eight chargers would overload 2×.)
- The proxy reads units off the wire: a charger sending `120000 W` is 120 kW, not 120,000.

Measured on the live site

```
load 1022 kVA / 1250 kVA (81.8 %)
bus 420.7 V L-L · 243 V L-N
line current 1403 A per phase
frequency 50.00 Hz (band 49.90–50.05)
```

New rule `R7_ELECTRICAL`: reported power must equal the meter's own V × I.

One VoltSentry node per site, joined into a network.



- Each node protects its own chargers. If the hub or the WAN goes down, detection and quarantine carry on locally.
- Every message is HMAC-SHA256 signed with that node's own key, with replay protection; TLS optional. Forged, impersonated and replayed nodes are refused.
- A quarantine at one site becomes a blocklist entry every site enforces within a second.

What no single site can see

One RFID card can only charge one car at a time. Sites share live sessions as salted hashes (never the card number), so a Vellore card used in Chennai while still charging in Vellore is blocked: `R8_TAG_CLONE` there, `R9_THREAT_INTEL` back home.

Tier-1 catches the loud attacks at zero latency.

RULE	CHECKS	TRIPS WHEN	ACTION
R1_STATE_ORDER	per-station FSM	MeterValues / StopTransaction with no live Authorize → StartTransaction	log
R2_PHYSICS	CC-CV envelope	power > 150 kW, or > 60 kW while SoC > 80%, or < 0	quarantine
R3_OSCILLATION	sliding window	≥ 6 start/stop transitions fleet-wide in 10 s	log
R4_SESSION_UNIQUE	connection registry	second handshake for a cpid with a live session	reject at handshake
R5_TXN_INTEGRITY	transaction map	MeterValues.transactionId unknown or owned by another cpid	quarantine
R6_METER_FRAUD	energy-residual rate	energy register pulling away from reported power	quarantine
R7_ELECTRICAL	meter consistency	reported power ≠ reported DC volts × amps	quarantine
R8_TAG_CLONE	card registry	RFID card already charging here or at another site	block card
R9_THREAT_INTEL	federation	card or charger another site reported	block / refuse

Tier-2 catches the one attack a rule cannot.

- Subtle drift stays inside every hard threshold by construction — so it is not a point outlier and a threshold engine stays silent.
- The fix is an engineered feature the proxy computes from the wire alone: `energy_residual = reported register - ∫ reported power dt`.
- Honest sessions hold this near zero. Any divergence between reported instantaneous power and the accumulating energy register makes it climb monotonically.
- Scored two ways: an **Isolation Forest** on the 5-dim session vector, and an offline **CUSUM** change-detector on the residual for corroboration and explainability.

- **The 5-dim vector**

```
[ power_kw,
  soc,
  dp_dt,
  duration_sec,
  energy_residual_kwh ]
```

`IsolationForest(n_estimators=100, contamination=0.02, random_state=42)`, score normalisation pinned at fit time. Alert on `score > 0.65`. Samples 1–2 of a session are not scored.

LIVE DEMO · 4 MINUTES

Five keystrokes. Five detections.

KEY	ATTACK	WHAT THE JUDGE SEES	CAUGHT BY
1	meter_spoof	CP-03 reports 5 kW but its own meter says 718 V × 167 A = 120 kW → quarantined on the first frame	R7 (+R6, ML)
2	fleet_oscillate	every bay stops and starts together once a second → transformer swings 82 % ↔ 0 % → fleet-wide badge	R3
3	session_shadow	duplicate handshake on a live cpid → shadow socket refused at the handshake	R4
4	subtle_drift	-2%/tick under-report, every value consistent → **no rule fires** → Risk Index past 0.65 ~10 s in; R6 ~35 s later	Tier-2 first
5	tag_clone	a Chennai bay presents a card still charging in Vellore → Authorize answered Blocked; Vellore alerted	R8 + R9
r	reset	clears quarantine, reconnects the fleet clean — ready for the next attack	—

The `subtle_drift` beat is the pitch: the one attack a rule engine structurally cannot catch, and the reason Tier-2 exists.

CREDIBILITY

What is real, and what is simulated.

REAL

- OCPP 1.6-J wire format, array framing, CALL/CALLRESULT correlation
- Per-station session FSM and transaction registry
- All detection logic — Tier-1 rules R1–R9, Tier-2 Isolation Forest + CUSUM maths
- Electrical units read off the wire (W/kW, Wh/kWh, V, A, Hz) and the site model in kVA
- Multi-site federation: signed node links, shared indicators, cross-site card-clone detection
- Active quarantine: ChangeAvailability downstream, socket close 4001, un-quarantine on reconnect
- Forensic JSON logging and the live NOC dashboard

SIMULATED / IN PROGRESS

- Charger fleet physics — a CC-CV battery model, not real hardware
- The CSMS backend — an ~80-line mock, swappable for SteVe or CitrineOS
- The attacks — synthesised; there is no public labelled OCPP-attack corpus
- Tier-2 baseline is fit on a recorded feed fixture, not yet an external dataset
- End-to-end added-latency instrumentation

Measured, not asserted.

184

automated tests passing — rules, ML, OCPP units, electrical model, pipeline, federation over real sockets

~16 µs

Tier-1 per MeterValues frame (11 readings, ~1 KB), mean; p99 ~19 µs over 200k frames

9 + 2

deterministic rules live, plus a two-model Tier-2 (Isolation Forest + CUSUM)

- Tier-2 is wired into the live relay — every telemetry frame carries a Risk Index; both meter-spoof and drift are flagged in the offline benchmark.
- Next: re-fit Tier-2 on a real dataset (ACN-Data / ElaadNL); instrument end-to-end latency; test against real charger hardware.

A real path to production.

- **Protocol**

  OCPP 2.0.1 device model, the three security profiles (Basic / TLS / mutual-TLS), ISO 15118 Plug & Charge, smart-charging profiles.

- **Deployment**

  Built: one node per site, federated through a signed hub, TLS optional. Next: horizontal scale via cpid-consistent-hash routing, and testing inline against a real open-source CSMS (SteVe / CitrineOS).

- **Detection**

  Threat intelligence already federates across sites. Next: Tier-2 retrained on real fleet CDRs, and federated learning so models improve without sharing raw session data.

Capacity math from the measured Tier-1 cost: one instance sustains thousands of frames/sec; a 10k-charger CPO at 0.1 Hz MeterValues ≈ 1k fps — a handful of instances.

V VOLTSENTRY

Inline. Transparent. Sub-millisecond.

A drop-in security layer for EV charging that catches billing fraud, grid attacks, session hijacks — and the slow drift a rule engine never will.

```
python -m simulator.csms → python -m proxy.main → python -m simulator.twin → npm run dev
```